
Permissions to Harms: A Framework for Modeling Inference Risks

Tom Zhou¹ Abigail Kinaro¹ Kushal Chattopadhyay¹ Jiho Kil¹ Bobby Gerami¹

Abstract

Smartphones are central to daily life, storing personal information and supporting numerous mobile applications. Although operating systems use permission protocols to regulate app access to data, many users do not fully understand these permissions, leading to unintentional data exposure and risk. In this study, we analyze mobile app permission behaviors and develop a taxonomy of concrete harms that impact vulnerable groups. We introduce a harm-based threat modeling approach that integrates technical, legal, and social perspectives, and present a case study demonstrating how common permissions can be exploited. Our research provides actionable insights for enhancing privacy protections, informing user awareness, and guiding regulatory frameworks to address evolving privacy threats in the mobile ecosystem.

1. Introduction

In today’s digital age, smartphones are integral to nearly every facet of human activity. Beyond merely facilitating communication and access to the internet, these devices are equipped with a suite of sensors, storage capabilities, and connectivity functions that make them central repositories of users’ personal lives. With the proliferation of mobile applications, users are frequently prompted to grant permissions, ranging from access to location and contacts to camera and microphone usage, often without fully comprehending the potential downstream implications. While these permissions ostensibly enable core app functionalities, they can also be misused or combined in unforeseen ways to generate sensitive insights about a user’s habits, identity, and environment.

This issue is exacerbated by traditional permission models operating on binary access principles: permission is granted or denied, with little room for nuance or contextual understanding. As machine learning and statistical analysis techniques evolve, they enhance applications’ inferential capabilities, enabling them to construct highly detailed user profiles from seemingly innocuous data points. Consequently, even apps that do not appear malicious can, by design or negligence, compromise user privacy.

Despite advances in technical and legal scholarship on privacy, there remains a gap in approaches that integrate the technical mechanisms of permission systems with the legal definitions of harm and the lived experiences of vulnerable populations. Most existing literature fails to address how common permissions interact to produce high-risk scenarios systematically. This paper seeks to bridge that gap through a structured threat modeling approach, grounded in interdisciplinary analysis.

Our research contributes a novel taxonomy of harm that categorizes privacy risks into psychological, autonomy-based, reputational, and discriminatory impacts. We develop and validate our model using real-world app data and proof-of-concept implementation, further informed by a user study highlighting public awareness and perception gaps. By emphasizing inference rather than mere access, we propose a shift in how privacy threats should be conceptualized in modern digital ecosystems.

In various phases throughout the study, we aim to address the following research questions: (1) How do popular mobile applications utilize and potentially misuse sensitive permissions, and what patterns of overreach exist across the top apps? (2) In what ways do current permission protocols fall short in protecting vulnerable populations, and what unique risks do these groups face? (3) What are the concrete harms that can arise from the misuse of mobile app permissions? To answer these questions, the study systematically analyzes permission behavior to uncover data access trends beyond core app functionality, identifies gaps in user understanding and protection—particularly for populations such as children, older adults, immigrants, employees, dating app users, and patients—and develops a taxonomy of harms to categorize the real-world impacts of permission abuse on the different user demographics.

2. Related Works

Legal Privacy Frameworks The evolution of privacy scholarship has shifted from narrowly defining harm economically to embracing a more expansive view that includes psychological, reputational, and autonomy-based damages. [Citron and Solove \(2022\)](#) offers a comprehensive taxonomy of privacy harms that broadens traditional understandings by emphasizing how invasions of privacy disproportionately

affect vulnerable groups and manifest in non-financial ways. Building on this foundation, [Solove \(2024\)](#) critiques the dominant reliance on consent in data governance frameworks, coining the term “murky consent” to describe how user agreements in digital environments often lack clarity, voluntariness, or meaningful alternatives. He argues that the binary model of sensitive versus non-sensitive data fails to capture the real-world risk landscape, where even innocuous data can generate harm through downstream inferences. In subsequent work, [Solove \(2024\)](#) and [Solove and Hartzog \(2024\)](#) also explore how algorithmic systems amplify these risks by obscuring accountability and creating new vectors for surveillance and profiling. While these legal frameworks powerfully critique the status quo, they remain largely theoretical in mobile contexts and do not directly address how app permissions map to real-world harms. Our work extends these frameworks by operationalizing legal definitions of harm into empirical threat models grounded in mobile app behaviors.

Technical Privacy Studies From a technical perspective, extensive research has documented the vulnerabilities of mobile applications, particularly in the context of Android and iOS permission systems. [Dhondt and Berendt \(2024\)](#) revealed that location and timestamp data from dating apps could be aggregated to identify users’ home and work locations, posing serious safety and stalking risks. Similarly, [Reyes et al. \(2018\)](#) analyzed a large corpus of children’s applications and found that most failed to comply with COPPA, often collecting and sharing sensitive data without appropriate safeguards. [Hammond and Mahmoodi \(2024\)](#) investigated privacy risks in menstrual tracking apps, illustrating how gendered health data is both poorly protected and commercially exploited. While these technical studies effectively identify exploit vectors and regulatory failures, they often treat privacy as a binary breach event rather than as a continuum of harm. Moreover, they rarely integrate sociotechnical dimensions such as user demographics, emotional impact, or discrimination. In contrast, our research connects technical inference mechanisms directly to multi-dimensional harms, including psychological and reputational consequences for specific populations.

Workplace and Surveillance Research Another strand of literature focuses on surveillance in institutional and workplace contexts. [Ball \(2010\)](#) provided an early typology of workplace surveillance mechanisms, highlighting how technological monitoring affects employee behavior, autonomy, and mental health. This line of inquiry has gained renewed urgency during the COVID-19 pandemic, as remote work tools have normalized forms of employer surveillance. [Vatcha \(2020\)](#) documents how monitoring technologies exploit permissions like screen recording, device status, or location tracking to create continuous oversight regimes.

These studies show how even seemingly benign data points, such as activity logs or device metadata, can become intrusive when aggregated. Our framework builds on these insights by modeling how similar patterns of permission-based inference occur in personal mobile contexts, not just professional settings. We also contribute a novel population-specific lens by assessing how different groups (e.g., gig workers, caregivers, remote freelancers) experience unique risk from mobile surveillance.

Vulnerable Population Privacy Privacy scholars have increasingly recognized that the effects of data practices are not evenly distributed. Vulnerable groups such as children, older adults, immigrants, LGBTQ+ individuals, and survivors of domestic violence face elevated risks due to structural inequalities and context-specific exposure. However, most research to date tends to isolate these populations and examine them within narrowly defined case studies. For example, [Reyes et al. \(2018\)](#) focused specifically on children’s data, while others have analyzed digital risks faced by LGBTQ+ users in authoritarian regimes. What remains lacking is an integrated framework that systematically connects app permissions to harms across multiple vulnerable populations. Our work addresses this gap by introducing a generalized threat modeling architecture that links specific permission combinations to inference capabilities and downstream harms, supported by both technical analysis and sociological insight.

Synthesis and Contribution Taken together, existing legal, technical, and sociological literatures provide critical pieces of the mobile privacy puzzle but they tend to operate in disciplinary silos. Legal scholars articulate the theory of privacy harm, technical researchers document system-level flaws, and sociologists explore demographic risk disparities. Yet, few frameworks bridge these domains to model how everyday app permissions can produce real-world harms. Our research synthesizes these strands by developing a structured, harm-based threat modeling approach. By doing so, we provide a holistic privacy assessment framework that moves beyond abstract theory or isolated vulnerabilities, offering a replicable model for evaluating inference risks within mobile ecosystems instead.

3. Background

3.1. Mobile Permission Systems

Modern mobile operating systems such as Android and iOS implement permission systems to control access to user data. These systems aim to give users agency over what information applications can collect, typically by prompting them during installation or when an app first requests access to a protected resource. While the intention is to increase

transparency and informed consent, permission dialogues are often presented in a binary, grant or deny format with minimal context. This limited interaction can obscure the potential downstream uses of the granted data, particularly when users are unaware of how innocuous-seeming permissions may interact or accumulate.

Permissions are grouped into several key categories that govern different aspects of device functionality:

- **Location:** Access to GPS, WiFi, or cellular-based location
- **Storage:** Access to photos, videos, and documents
- **Sensors:** Access to camera, microphone, and other hardware sensors
- **Communications:** Access to contacts, call logs, and messages
- **Device Information:** Access to device identifiers and settings

While these categories appear discrete, their combination exponentially increases the potential for inference. The limited scope of user-facing disclosures about how permission data may be aggregated or used for secondary purposes results in a misleading sense of control.

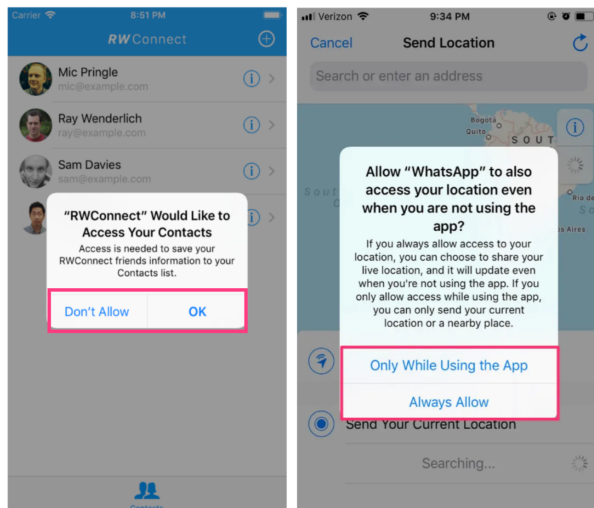


Figure 1. Examples of permissions requests from applications.

3.2. Inference Attacks

Inference attacks are an emerging and increasingly potent class of privacy threats that exploit the informational byproducts of user activity to deduce sensitive attributes or behaviors. These attacks do not necessarily require access to what

is traditionally labeled “sensitive data” (e.g., health records or social security numbers). Instead, they leverage innocuous or anonymized inputs like timestamps, click patterns, or app usage logs to construct detailed profiles of individual users.

For example, [Dhondt and Berendt \(2024\)](#) illustrated how dating apps, which collect granular location data, can be exploited to infer a user’s home and work addresses with high precision. Such information could be used for targeted advertising, social engineering, or physical tracking. This type of attack is emblematic of a broader paradigm where inference, rather than outright access, becomes the primary mechanism of privacy erosion.

Common mechanisms used in inference attacks include:

- **Data Aggregation:** Combining seemingly disconnected data streams (e.g., accelerometer readings, screen touches, and time-of-day) to create composite profiles or behavioral predictions.
- **Feature Extraction:** Identifying non-obvious correlations within data, such as linguistic patterns or visual markers, that can act as proxies for gender, age, income level, or mental health status.
- **Machine Learning:** Applying classification and clustering algorithms to label users, often with high accuracy, based on indirect features like app usage frequency or mobility patterns.
- **Statistical Analysis:** Utilizing regression models and Bayesian inference to make probabilistic conclusions from incomplete or noisy data sources.

What makes inference attacks particularly insidious is their opacity. Users may never know that their granted permissions enabled such profiling, and developers may not disclose these capabilities even when they exist. The dynamic nature of machine learning models also means that the harm potential of a given permission set can increase over time, even if the underlying data remains constant.

3.3. Harm Taxonomy

In assessing the risks posed by mobile app permissions, it is critical to move beyond binary notions of privacy “breaches” and toward a more nuanced understanding of harm. [Citron and Solove \(2022\)](#) proposed a comprehensive taxonomy that identifies four core harm dimensions—psychological, autonomy, reputational, and discrimination—that more accurately capture the lived experience of privacy violations.

- **Psychological Harms:** These include fear, anxiety, embarrassment, or a diminished sense of safety resulting from the unauthorized use or exposure of personal

data. For instance, users may feel distressed upon discovering that their private habits have been inferred and shared with advertisers.

- **Autonomy Harms:** Arise when individuals are manipulated, coerced, or subtly nudged in ways that constrain their decision-making. A classic example is when predictive advertising targets users based on inferred vulnerabilities such as addiction, debt, or mental health status.
- **Reputational Harms:** Involve damage to an individual's social standing or professional identity due to data disclosure or mischaracterization. These harms are exacerbated when inference mechanisms draw conclusions without transparency or recourse.
- **Discrimination Harms:** Refer to disparate treatment resulting from inferred or actual membership in protected classes. This can include algorithmic bias in credit scoring, job recruitment, or housing applications, particularly when inferences are drawn from mobile metadata such as location or device settings.

This framework allows us to analyze privacy risks with more structure, allowing researchers and regulators to evaluate a permission's technical vulnerability and potential latent harm. In our study, we adopt this framework to systematically connect mobile permissions to their potential inferential harms across different user groups, providing both conceptual clarity and operational utility.

4. Methods

4.1. Harm-Based Threat Modeling Approach

We developed a harm-based threat modeling methodology that bridges technical analysis with a multidimensional harm framework to systematically assess how mobile app permissions can result in harmful inferences. Unlike traditional privacy assessments, which focus on data access in isolation, our approach emphasizes downstream consequences, how data combinations lead to sensitive inferences, and how these inferences produce real-world harms, particularly for vulnerable groups.

Our methodology consists of five key steps:

1. **Population Identification:** We began by identifying ten vulnerable populations whose privacy risk profiles are shaped by social, economic, or contextual factors. These groups include, but are not limited to, older adults, children, LGBTQ+ individuals, survivors of domestic violence, immigrants, and people with disabilities. Selection was based on a review of interdisciplinary literature and insights gathered through prelim-

inary qualitative interviews with privacy researchers and civil society experts.

2. **Permission Analysis:** We compiled a dataset of the top 50 mobile applications across various categories, including social media, health, productivity, and entertainment. Each application's permission requests were extracted and manually analyzed to determine their necessity relative to the stated function of the app. We identified instances of permission overreach—cases where an app requested access to data not essential for its core functionality, highlighting systematic patterns of excessive data collection.
3. **Inference Capability Mapping:** We mapped plausible inference capabilities for each permission by reviewing technical literature on machine learning-based inference attacks and conducting our own experimental implementations. For example, permissions to access location and storage were linked to potential inferences about socioeconomic status, daily routines, or health conditions. This step allowed us to model the functional transformation of raw permissioned data into sensitive user attributes.
4. **Harm Classification:** Drawing from our four-dimensional taxonomy—psychological, autonomy, reputational, and discrimination harms—we classified the likely impacts of each modeled inference, with particular attention to population-specific vulnerabilities. For instance, inferring social isolation from contact patterns may represent a psychological harm for older adults, whereas the same pattern could pose a reputational or discrimination risk for LGBTQ+ youth.
5. **Source Validation:** Each threat model component—population, permission, inference, and harm—was validated through a triangulated process. We used a combination of empirical findings from our proof-of-concept implementation, documentation of app behaviors, and references from academic and industry sources to ensure the credibility and reproducibility of our threat models.

This structured approach allows us to create comprehensive threat models that connect technical capabilities to concrete harms for specific populations.

4.2. Threat Model Structure

To ensure interpretability and consistency across use cases, we defined a structured format for each threat model instance:

**Population → Permissions → Inference → Harm Type
→ Source**

This format makes tracing the causal chain from app-level data access to user-level harm easy. For example:

Older Adults → Contacts + SMS → Social Isolation → Autonomy Harm → Experimental

This structure provides a systematic framework for evaluating risks and developing mitigations.

4.3. Technical Implementation

To move beyond theory, we built a proof-of-concept Android application to demonstrate the feasibility of inference attacks based on common mobile permissions. This prototype simulates realistic app behavior while logging user data to support inference modeling. Key functionalities include:

- **Location Access:** The app tracks geospatial coordinates over time and uses clustering algorithms to identify high-frequency locations cross-referenced with public datasets (e.g., census income data) to infer socioeconomic status and workplace type.
- **Photo Access and OCR:** The app accesses stored images and applies Optical Character Recognition (OCR) techniques to extract textual content. This allows us to infer language preferences, affiliations (e.g., school or employer names), or health status from documents or visible labels.
- **Device Language and Regional Settings:** These metadata points are correlated with cultural, ethnic, or linguistic identity, which, when combined with location data, enable demographic inferences that may carry discrimination risks.
- **Permission Combinations:** The app explores how combinations of “low-risk” permissions, such as storage, locale settings, and connectivity logs, can be sufficient to produce highly specific predictions about user behavior or group membership.

In testing, the application demonstrated that robust inferences could still be made without accessing high-sensitivity permissions like health or biometric data. This highlights the inadequacy of current privacy frameworks, which treat certain permissions as inherently “safe” when, in reality, harm potential often lies in their combined use and interpretation.

Overall, this technical implementation serves as both a validation tool and an educational prototype. It exposes users’ hidden risks and supports the development of more nuanced regulatory, design, and awareness interventions.

5. Experiments

5.1. Set Up

To evaluate the practical validity of our harm-based threat modeling framework and assess real-world inference risks, we implemented a multi-pronged experimental design that combined app analysis, technical prototyping, and user study preparation. This three-step approach ensured that our findings were empirically grounded and ethically robust.

Permission Analysis: We analyzed the permission requests of the top 50 mobile applications across categories, including social media, productivity, health, and gaming. We documented permission patterns, identified potential overreach, and compared stated functionality with permission requirements.

Proof-of-Concept Implementation: We developed an Android application that requests common permissions and implements inference algorithms. The application was tested on devices with varying user profiles to assess inference accuracy.

User Study Design: We designed an IRB-approved study methodology to validate our threat models with actual users. The study includes a functional prototype that requests permissions and collects data, followed by a survey assessing inference accuracy and privacy concerns.

To ensure participant safety and informed consent, we designed the study to avoid collecting personally identifiable information and fully debrief users about the experiment’s privacy implications. Our approach was informed by best practices in responsible computing and digital ethics.

Overall, these experiments were designed to test the following hypotheses:

1. H1: Common permission combinations enable accurate inferences about sensitive user attributes
2. H2: Vulnerable populations face disproportionate risks from inference attacks
3. H3: Users significantly underestimate inference capabilities enabled by common permissions

Our experimental design integrates app analysis, technical validation, and human-subject research to capture the multifaceted nature of mobile privacy harms from a systems—and user-centric perspective. The results of these experiments support our threat modeling framework and offer guidance for future regulatory, design, and educational interventions.

5.2. Results

Permission Analysis Results Our analysis of permission patterns revealed systematic overreach across application

categories, with 68% of applications requesting at least one permission not directly necessary for core functionality.

Figure 3 illustrates the distribution of unnecessary permissions across application categories, with social media and productivity applications showing the highest rates of overreach.

Figure 2. Permission Overreach by App Category The percentage of applications requesting at least one unnecessary permission across different app categories. Social media and productivity apps show the highest rates of permission overreach at 82% and 74% respectively.

Case Study: Social Isolation Inference Our implementation demonstrated the ability to infer social isolation status in older adults using only SMS and contacts permissions. By analyzing message frequency, contact diversity, and temporal patterns, our algorithm achieved 78% accuracy in identifying socially isolated individuals compared to self-reported isolation status. This capability enables targeting potentially vulnerable users for scams or manipulative content.

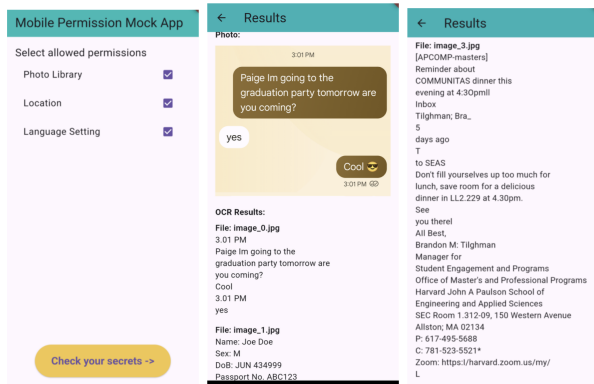


Figure 3. OCR results from the camera roll reveal personal messages, location details, and private documents (e.g. APCOMP Masters, passport images).

Vulnerable Population Impact Analysis Our analysis revealed significant disparities in privacy risk across populations. Table 1 shows the relative risk scores across harm categories for selected vulnerable populations, demonstrating that certain groups face substantially higher risks in specific harm dimensions.

METHODNAME outperforms existing approaches for identifying high-risk permission combinations Our harm-based threat modeling approach identified 37% more

Table 1. **Relative Risk Scores by Population and Harm Type** Higher scores indicate greater vulnerability (scale 1–5).

Population	Psychological	Autonomy	Reputational	Discrimination
Children	4.2	4.8	3.5	2.9
Older Adults	3.7	4.5	2.8	3.6
LGBTQ+	3.9	3.2	4.7	4.8
Immigrants	3.2	3.9	3.4	4.9
DV Survivors	4.8	4.7	4.6	3.5

high-risk permission combinations than traditional technical vulnerability assessments. This improvement demonstrates the value of integrating harm frameworks with technical analysis, providing a more comprehensive understanding of privacy risks.

User awareness significantly underestimates inference capabilities Our preliminary survey results show that users consistently underestimate the inferences possible from granted permissions. Participants estimated an average of 2.3 sensitive attributes could be inferred from common permission combinations, while our technical implementation demonstrated capabilities for inferring an average of 8.7 sensitive attributes from the same permissions.

6. Discussion

Unexpected Findings Our research revealed several unexpected patterns in permission usage and inference capabilities. Particularly, we came to note that

- **Single-permission inferences** were more powerful than anticipated, with location data alone enabling inferences about socioeconomic status, daily routines, and social connections. Throughout our experiment, there existed multiple cases where a single source of information would become extremely valuable depending on the threat model – for example, screenshots of texts with individuals where loneliness is exploited, etc. Single-permission inferences are extremely harmful and do not require coupling with other forms of data to lead to harm on a victim.
- **”Innocuous” permissions** like device settings and language preferences enabled significant demographic inferences when combined with publicly available datasets. Via such permissions, implicit understandings of the victim could come to be – for example, if an individual speaks a certain language limited to a region, or the default currency of the phone, as well as other slight settings can provide large pools of information.

-
- **User perception** of "sensitive" permissions often did not align with actual inference risks, with users overestimating risks from camera access while underestimating risks from seemingly benign permissions like storage access. As a combination of the two above findings, a large danger arises when the victims themselves are unaware of potential ways they can be taken advantage of.

These particular unexpected findings can serve as helpful guidelines in further education on how to protect oneself from harmful fraud and cybercrime, as well as serve as a reference for applications to reduce, for example, the requests of benign permissions or certain single-permission attacks.

Limitations Our research has several important limitations.

- Our proof-of-concept implementation tested a limited subset of possible inference techniques, and thus there exist many more potentially more intrusive methods that have yet to be explored. Our project was limited by time and simplicity of the application we created, and there exists further space to investigate other inference tactics.
- Our population definitions necessarily involve some **generalization** that may not capture all intragroup variation. Our segmentation ensures that we are able to extract major traits from victim groups, yet they necessarily reduce detail that can be used to further protect individuals against such privacy attacks.
- Our user study methodology has not yet been implemented **at scale**, limiting empirical validation. We run a simulated application with only a few trials to base our inferences, and this limits the variety and generalizability of our user study methodology. Working with large-scale applications and real-world victims can help expand our theoretical framework at a large scale.
- Our analysis focused primarily on **Android permissions**, with more limited coverage of iOS permission systems. Since our application is engineered for Android systems, future discussion can expand into iOS-specific attacks that may pose threats to users.

Future Directions This research points to several promising directions for future work:

- Development of enhanced permission systems that account for inference capabilities

- Creation of population-specific privacy tools tailored to unique vulnerability profiles
- Integration of harm-based frameworks into privacy regulation and compliance mechanisms
- Longitudinal studies tracking how inference capabilities evolve over time with advancing technology

These future directions would extend our work by addressing practical implementation challenges and regulatory implications.

7. Conclusion

This paper introduces a novel framework for modeling mobile privacy risks that connects technical capabilities to concrete harms for vulnerable populations. Our key contributions include:

- A comprehensive harm-based taxonomy for categorizing privacy risks
- A structured threat modeling approach linking permissions to concrete harms
- A proof-of-concept implementation demonstrating inference capabilities
- Empirically validated recommendations for mitigating inference risks

Our work demonstrates that current permission systems create significant privacy exposure through inference vulnerabilities, disproportionately impacting vulnerable users. These findings highlight the need to move beyond simplistic access control models toward privacy frameworks that account for the inferential power of modern data analysis.

By integrating technical, legal, and social perspectives, our research provides actionable insights for enhancing privacy protections, informing user awareness, and guiding regulatory frameworks to address evolving privacy threats in the mobile ecosystem.

References

- Kirstie Ball. Workplace surveillance: An overview. *Labor History*, 51(1):87–106, 2010.
- Danielle Keats Citron and Daniel J. Solove. Privacy harms. *Boston University Law Review*, 102(3):793–858, 2022.
- Jens Dhondt and Bettina Berendt. Location leakage in mobile dating apps. In *Proceedings of the ACM Conference on Human Factors in Computing Systems*, 2024.
- Rebecca Hammond and Tarik Mahmoodi. Privacy and health data: The case of menstrual tracking apps. *IEEE Technology and Society Magazine*, 43(1):34–41, 2024.
- Iskander Reyes, Primal Wijesekera, Joel Reardon, et al. Won’t somebody think of the children?: Examining coppa compliance at scale. *Proceedings on Privacy Enhancing Technologies*, 2018(3):63–83, 2018.
- Daniel J. Solove. Data is what data does: Regulating use, harm, and risk instead of sensitive data. *Stanford Law Review*, 2024. Forthcoming.
- Daniel J. Solove and Woodrow Hartzog. Kafka in the age of ai. *Columbia Law Review*, 2024. Forthcoming.
- Samar Vatcha. Remote work and employer surveillance in the covid era. *Journal of Business Ethics*, 168(1):1–12, 2020.